

Cirque Corporation

Vulnerability Management Policy

Generated: January 09, 2026

4.2. Risk Analysis a. Assess the likelihood of a threat exploiting a vulnerability to cause an information security incident using Low, Medium, or High qualitative ratings. b. Assess the potential impact (e.g., financial, reputational, legal, operational) of such an incident on Cirque Corporation's business objectives using Low, Medium, or High qualitative ratings. c. Combine likelihood and impact to determine the level of inherent risk (e.g., High, Medium, Low).

4.3. Risk Evaluation a. Compare the assessed risk levels against Cirque Corporation's established risk acceptance criteria. b. Prioritize risks based on their severity and alignment with risk acceptance levels.

4.4. Risk Treatment a. Select appropriate risk treatment options based on the risk evaluation: * Modify: Implement controls to reduce the risk (e.g., encryption, access controls, training). * Retain: Accept the risk as it falls within acceptable levels or treatment is not cost-effective. * Avoid: Cease the activity that generates the risk. * Share/Transfer: Transfer the risk to another party (e.g., insurance, outsourcing with robust contracts). b. Develop and implement a Risk Treatment Plan (IS-CIRQ-D-005-G) detailing the selected controls, responsibilities, and timelines. c. Implement controls from ISO 27001 Annex A as appropriate.

4.5. Risk Monitoring and Review a. Identified risks and the effectiveness of implemented controls will be regularly monitored. b. A formal review of high risks will be conducted quarterly. c. The entire risk assessment and treatment processes will be reviewed periodically to ensure their ongoing suitability and effectiveness. d. Risks will be re-evaluated when significant changes occur (e.g., new systems, new business processes, new threats).

5. Risk Acceptance Criteria

The Executive Committee will define and approve the criteria for accepting information security risks. Cirque Corporation maintains a low risk appetite, aiming to mitigate almost all

identified risks, even those initially assessed as minor, where feasible and cost-effective. Risks exceeding the defined acceptance criteria must be treated.

6. Roles and Responsibilities

Executive Committee: Approves the Risk Management Policy and Risk Acceptance Criteria.

IT Manager: Accountable for the overall risk management process, including facilitating risk assessments, maintaining the Risk Assessment Register, and reporting on risk status.

Department Managers/Process Owners: Responsible for identifying and assessing risks within their operational areas and contributing to risk treatment plans.

All Employees: Responsible for reporting identified vulnerabilities or threats.

7. Related Documents

IS-CIRQ-PR-002-G: Information Security Risk Assessment Procedure

IS-CIRQ-PR-003-G: Information Security Risk Treatment Procedure

IS-CIRQ-F-001-G: Risk Assessment Register

IS-CIRQ-D-005-G: Risk Treatment Plan (RTP)

IS-CIRQ-D-006-G: Statement of Applicability (SoA)

8. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque Corporation's risk appetite, business environment, or legal/regulatory landscape.